



CHAPTER 12

DIGITAL SIGNATURES

OUTLINES

1. Introduction to Digital Signature.
2. Design of Digital Signature.
3. Cryptanalysis on Digital Signature.
4. Practical Digital Signature Schemes.

LEARNING OBJECTIVES

In the end of this Chapter 12, students will be able:

1. To understand the **concept and importance** of **digital signature** in cryptography.
2. To understand in depth the **design of digital signature** using different approaches.
3. To understand and describe the **cryptanalysis** on digital signature.
4. To understand the **practical digital signature schemes**.

INTRODUCTION TO DIGITAL SIGNATURE

INTRODUCTION TO DIGITAL SIGNATURE

- **Analogy**: A person signs a document to show that document is originated from (was approved) by him/her. It can be viewed like handwritten signatures on documents.
- A **digital signature** in cryptography is therefore a mathematical technique used to validate the **authenticity** and **integrity** of a document or message.
- This scheme is worked through the **public-key cryptography**, where signing and verifying the signature are done using different keys.
 - The **private key** K_{prv} is used to **sign** the message (document).
 - The **public key** K_{pub} is used to **verify** the signature.

INTRODUCTION TO DIGITAL SIGNATURE

- **Comparison** between conventional (handwritten) signature and digital signature.

1. Inclusion.

- A conventional signature is included and is part of the document.
- A digital signature is computed and sent separately with document.

2. Verification technique.

- A receiver compares the conventional signature on the document with the signature on the file to verify its authenticity.
- A receiver performs mathematical operations on the combination of both message and digital signature to verify its authenticity.

INTRODUCTION TO DIGITAL SIGNATURE

3. Relationship.

- A conventional signature is usually a one-to-many relationship between a signature and documents.
- A digital signature is a one-to-one relationship (unique) between a signature and a document.

4. Duplicity.

- A conventional signature can be distinguished between the copied and the original.
- A digital signature is indistinguishable unless specific time-factor is imposed on it.

INTRODUCTION TO DIGITAL SIGNATURE – WHY DO WE NEED IT?

- Message authentication protects two parties who exchange the message from any third party (message integrity).
- However, it does not protect two parties against each other (non-repudiation). Hence, several forms of dispute between the parties are possible.
- It a situation where there is no complete trust between the communicating parties (sender and receiver), then other solutions more than authentication is needed.

DESIGN OF DIGITAL SIGNATURE

DESIGN OF DIGITAL SIGNATURE – GENERIC MODEL (FRAMEWORK)

- Suppose two users (says Alice and Bob) wants to communicate securely. Alice wants to send a message to Bob.
 1. Alice hashes the message M using a cryptographic hash function $H(\cdot)$ to produce $h = H(M)$.
 2. The hash value is then signed using a digital signature scheme with her private key Prv_A to produce a signature $\sigma = \text{Sig}(\text{Prv}_A, h)$.
 3. The message M and signature σ are sent to Bob as concatenated ciphertext $C = (M \parallel \sigma)$.

DESIGN OF DIGITAL SIGNATURE – GENERIC MODEL (FRAMEWORK)

4. Bob when receiving the ciphertext $C = (M \parallel \sigma)$, extracts M from $(M \parallel \sigma)$ and computes the hash value $h = H(M)$.
5. Next, Bob verifies the validity of the signature using the same signature algorithm with Alice's public key $h' = \text{Vrfy}(\text{Pub}_A, \sigma)$ and compares it with the h computed.
6. If $h' = h$, it tallies and Bob accept the signature as valid signature and message integrity and authenticity are protected. Otherwise, Bob rejects the ciphertext.

DESIGN OF DIGITAL SIGNATURE – GENERIC MODEL (FRAMEWORK)

- In the generic model, if the algorithm returns the **valid verification decision**, then Bob is assured that Alice must have signed the message, since **none possesses Alice's private key Prv_A** other than herself.
- In addition, it is impossible for an attacker/adversary to alter the message without the access to Alice's private key Prv_A . Hence, the **message is authenticated** with respect to its **data origin** and **data integrity**.

DESIGN OF DIGITAL SIGNATURE – REQUIREMENTS

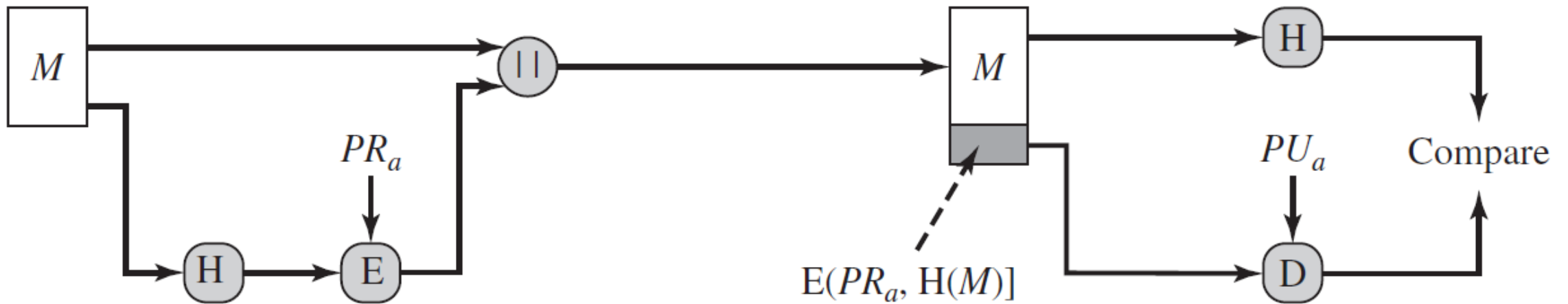
- For a digital signature scheme to be secure and practical, several requirements should be met.
 1. The signature must be a bit pattern that depends on the message being signed.
 2. The signature must contain some information unique to the sender to prevent both forgery and denial.
 3. The signature must be relatively easy to be produced and verified by any communicating parties.

DESIGN OF DIGITAL SIGNATURE – REQUIREMENTS

4. The signature must be **computationally infeasible for** an attacker to forged it, either by **constructing a new message for an existing digital signature** or by **constructing a fraudulent digital signature for a given message**.
5. It must be practical to retain a copy of the digital signature in storage.

DESIGN OF DIGITAL SIGNATURE THE **RSA** APPROACH

DESIGN OF DIGITAL SIGNATURE – THE RSA APPROACH



(a) RSA approach

DESIGN OF DIGITAL SIGNATURE – THE RSA APPROACH

1. The message M to be signed is input into a hash function $H(\cdot)$ that produces a secure hash code $h = H(M)$ of fixed length.
2. The hash code h is then encrypted (signed) using sender's private key to produce the signature $\sigma = \mathbf{E}(\text{PR}_a, h)$.
3. Both the message and the signature ($M \parallel \sigma$) are sent over to the receiver.
4. The receiver extract the message M from ($M \parallel \sigma$) and compute the hash code $h' = H(M)$.

DESIGN OF DIGITAL SIGNATURE – THE RSA APPROACH

5. The receiver decrypts (verifies) the signature σ using the sender's public key PU_a to recover the hash code $h = \mathbf{D}(PU_a, \sigma)$.
 6. The receiver matches the computed h' and the decrypted h . If $h' = h$, then the signature is accepted as valid signature. Otherwise, it rejects it.
- Since only the sender knows the private key PR_a , he can be the only who produce a valid signature.

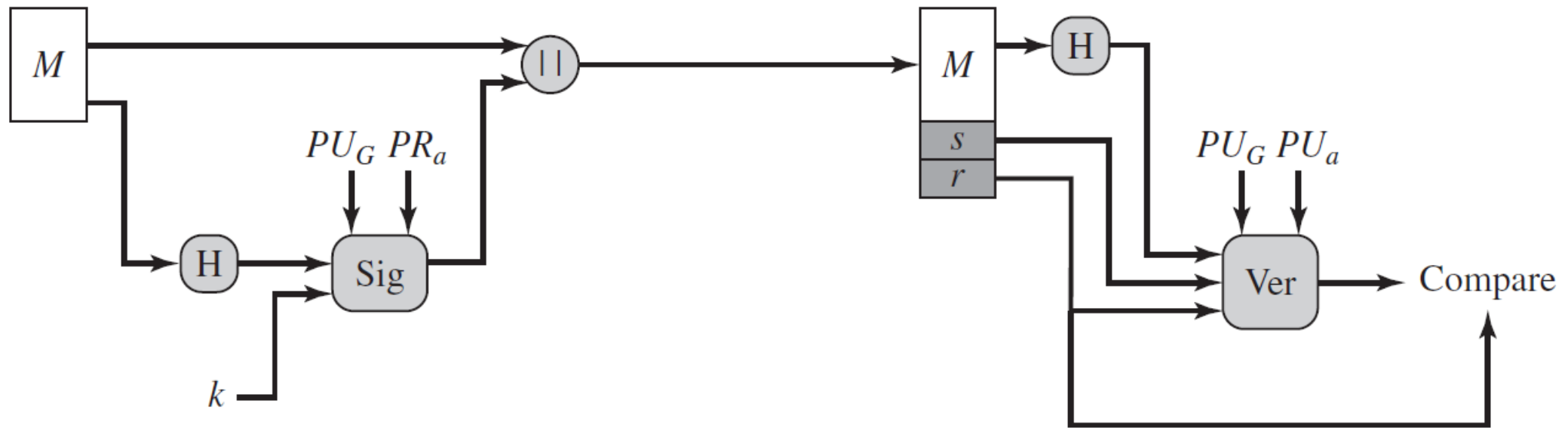
DESIGN OF DIGITAL SIGNATURE

THE **DSS** APPROACH

DESIGN OF DIGITAL SIGNATURE – THE DSS APPROACH

- NIST in 1991 has published Federal Information Processing Standard FIPS 186, known as the **Digital Signature Standard (DSS)**.
- The DSS makes use of the **Secure Hash Algorithm (SHA)** and presents a new digital signature technique, known as the **Digital Signature Algorithm (DSA)**.
- DSS has gone through several revision updates, and the current version also incorporates digital signature algorithms based on RSA and on elliptic curve cryptography.
- In this course, we consider only the original DSS algorithm and its approach.

DESIGN OF DIGITAL SIGNATURE – THE DSS APPROACH



(b) DSS approach

DESIGN OF DIGITAL SIGNATURE – THE DSS APPROACH

1. The message M to be signed is input into a hash function $H(\cdot)$ that produces a secure hash code $h = H(M)$ of fixed length.
2. The hash code h is then signed using a **signature function** with input of a random number k generated for this particular signature, the sender's private key PR_a , and the global public key PU_G , $\sigma = (r, s) = \text{Sig}(PR_a, PU_G, k, h)$. This global public key is a set of parameters known to a group of communicating principals.
3. The output signature σ contains two components s and r . They are all sent along with the message M as $(M \parallel s, r)$ to the receiver.

DESIGN OF DIGITAL SIGNATURE – THE DSS APPROACH

4. The receiver extract the message M from $(M \parallel s, r)$ and compute the hash code $h' = H(M)$.
 5. Both the computed h' and σ are input into a **verification function**, together with the sender's public key PU_a , and the global public key PU_G , $r' = \text{Vrfy}(PU_a, PU_G, \sigma, h')$.
 6. If the computed r' matches the signature component r from $(M \parallel s \parallel r)$, that is $r' = r$, the signature is accepted as a valid signature. Otherwise, it rejects it.
- **Note:** The signature function is a function such that only sender with knowledge of the private key PR_a can produce the valid signature.

ATTACKS & CRYPTANALYSIS ON DIGITAL SIGNATURE

ATTACKS & CRYPTANALYSIS

ON DIGITAL SIGNATURE

- Like encryption scheme, digital signature is also exposed to attacks and cryptanalysis. For an **encryption scheme**, an adversary (attacker) tries all his ability to either **decrypt the ciphertext** or to **find the encryption key** using any methods.
- For **digital signature**, on the other hand, an adversary (attacker) tries to **forge another valid signature for a message** that he intercepted or **find the signing key** using any methods.

ATTACKS ON DIGITAL SIGNATURE

- The attacks on digital signature can be categorized into the following five environments, depending on how much the ability an adversary (attacker) has.
1. **Key-Only Attack** (*Weakest*). The adversary A knows only sender's public key. His target is to find out the corresponding private key for signing.
 2. **Known Message Attack**. The adversary A is given access to a set of messages and their corresponding signatures (M_i, σ_i) .

ATTACKS ON DIGITAL SIGNATURE

3. **Generic Chosen Message Attack (Generic CMA)**. The adversary A chooses a list of message M_i of his choice **without knowing sender's public key**. The adversary A next obtains from the sender's valid signatures for the chosen message M_i .
4. **Directed Chosen Message Attack (Directed CMA)**. Similar to Generic CMA, but the adversary A now **has the knowledge of sender's public key**.
5. **Adaptive Chosen Message Attack (Adaptive CMA)** (*Strongest*). The adversary A may request from the sender the signatures of the chosen messages M_i , depending on the previously collected message-signature pairs (M_i, σ_i) .

CRYPTANALYSIS ON DIGITAL SIGNATURE

- As stated, an adversary's ultimate target in digital signature is to either **forge a valid signature for a message**, or to **find out the signing key**.
 - Hence, there are **four possible targets** that an adversary can achieve when attacking a signature scheme.
1. **Total Break** (***Strongest***). The adversary A found the signing key (the sender's private key). In this case, the signature scheme is **totally broken**.

CRYPTANALYSIS ON DIGITAL SIGNATURE

2. **Universal Forgery**. The adversary A found an efficient signing algorithm (not the signature algorithm that the sender used) that provides an equivalent way of constructing a valid signature σ_i on arbitrary messages M_i .
3. **Selective Forgery**. The adversary A forged a valid signature σ for a particular message M of his choice.
4. **Existential Forgery** (*Weakest*). The adversary A forged a valid signature σ for at least one existing message M given. In achieving this target, the adversary A has **no control over the message M** .

CRYPTANALYSIS ON DIGITAL SIGNATURE

- The current **security proof** approach of a **digital signature scheme** is to achieve the **Existential Unforgeability under Adaptive Chosen Message Attack (EUF-CMA)**.
- In other words, under the **STRONGEST** attack environment (**Adaptive CMA**) the adversary has, the adversary is still **FAILED** to **FORGE** any signature for a given message (**Existential Forgery**).

SECURITY PROOF

ENCRYPTION VS DIGITAL SIGNATURE

	Encryption	Signature
Security aspect	Secrecy of Ciphertext	Validity of Signature
Attacker's Strongest Attack	Chosen Ciphertext Attack (CCA)	Chosen Message Attack (CMA)
Attacker's Weakest Target	To distinguish among two messages (m_0, m_1) , which is encrypted as C .	To forge a valid signature σ based on all the existed message M learned.
Proof of Security	Indistinguishability against Chosen Ciphertext Attack (IND-CCA)	Existential Unforgeability under Chosen Message Attack (EUF-CMA)

PRACTICAL **DIGITAL SIGNATURE** **SCHEMES**

PRACTICAL DIGITAL SIGNATURE SCHEMES – THE DIGITAL SIGNATURE ALGORITHM (DSA)

- The **Digital Signature Algorithm (DSA)** is designed based on the difficulty of computing the Discrete Logarithm Problem (DLP).
- This DSA scheme is based on the signature scheme originally presented by ElGamal and Schnorr in 1985.

PRACTICAL DIGITAL SIGNATURE SCHEMES – THE DIGITAL SIGNATURE ALGORITHM (DSA)

Global Public-Key Components

- p prime number where $2^{L-1} < p < 2^L$
for $512 \leq L \leq 1024$ and L a multiple of 64;
i.e., bit length of between 512 and 1024 bits
in increments of 64 bits
- q prime divisor of $(p - 1)$, where $2^{159} < q < 2^{160}$;
i.e., bit length of 160 bits
- $g = h^{(p-1)/q} \bmod p$,
where h is any integer with $1 < h < (p - 1)$
such that $h^{(p-1)/q} \bmod p > 1$

User's Private Key

x random or pseudorandom integer with $0 < x < q$

User's Public Key

$$y = g^x \bmod p$$

User's Per-Message Secret Number

k = random or pseudorandom integer with $0 < k < q$

PRACTICAL DIGITAL SIGNATURE SCHEMES – THE DIGITAL SIGNATURE ALGORITHM (DSA)

Signing

$$r = (g^k \bmod p) \bmod q$$

$$s = [k^{-1} (H(M) + xr)] \bmod q$$

$$\text{Signature} = (r, s)$$

M = message to be signed

$H(M)$ = hash of M using SHA-1

M', r', s' = received versions of M, r, s

Verifying

$$w = (s')^{-1} \bmod q$$

$$u_1 = [H(M')w] \bmod q$$

$$u_2 = (r')w \bmod q$$

$$v = [(g^{u_1} y^{u_2}) \bmod p] \bmod q$$

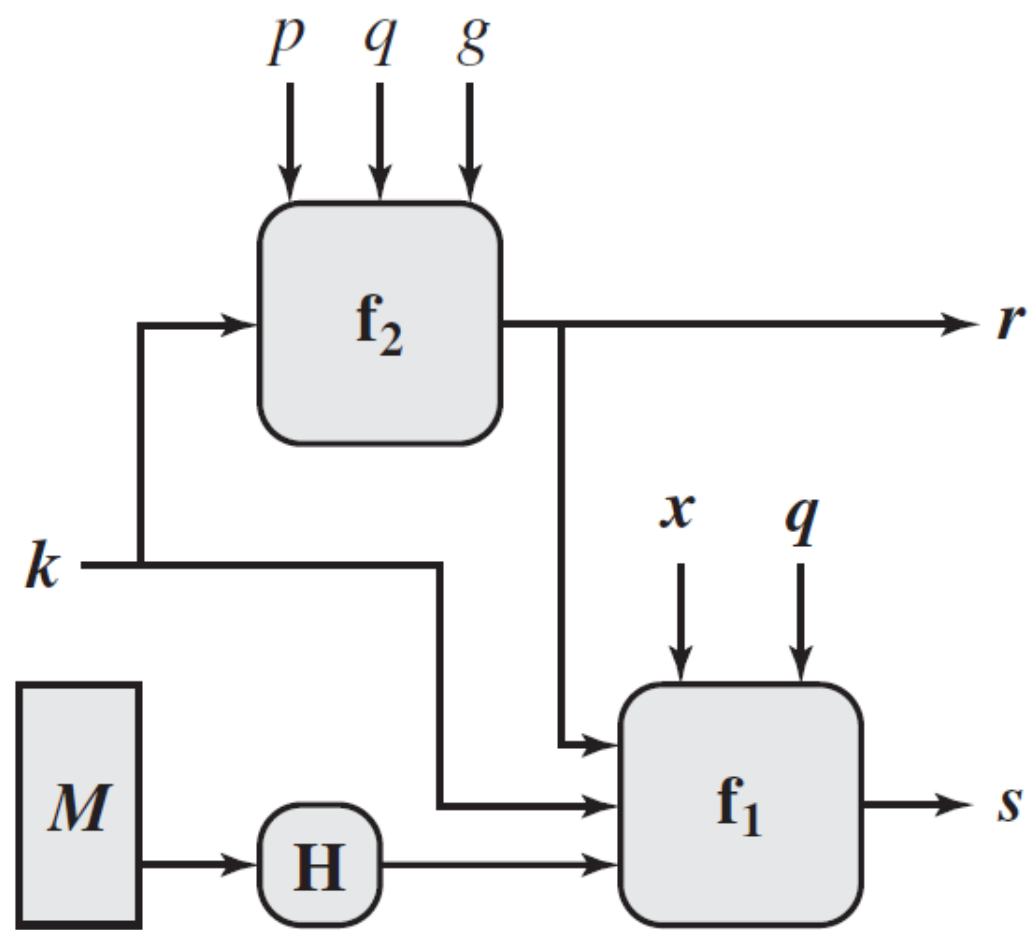
$$\text{TEST: } v = r'$$

THE DIGITAL SIGNATURE ALGORITHM (DSA) – PROOF OF CORRECTNESS

$$\begin{aligned}v &= g^{u_1} \cdot y^{u_2} \\&= g^{wH(M)} \cdot (g^x)^{rw} \\&= g^{w(H(M)+xr)} \\&= g^{w(H(M)+sk-H(M))} \\&= g^{w(sk)} \\&= g^{s^{-1}(sk)} \\&\equiv [g^k \pmod{p}](\pmod{q})\end{aligned}$$

$$\begin{aligned}s &= k^{-1}(H(M) + xr) \\xr &= sk - H(m)\end{aligned}$$

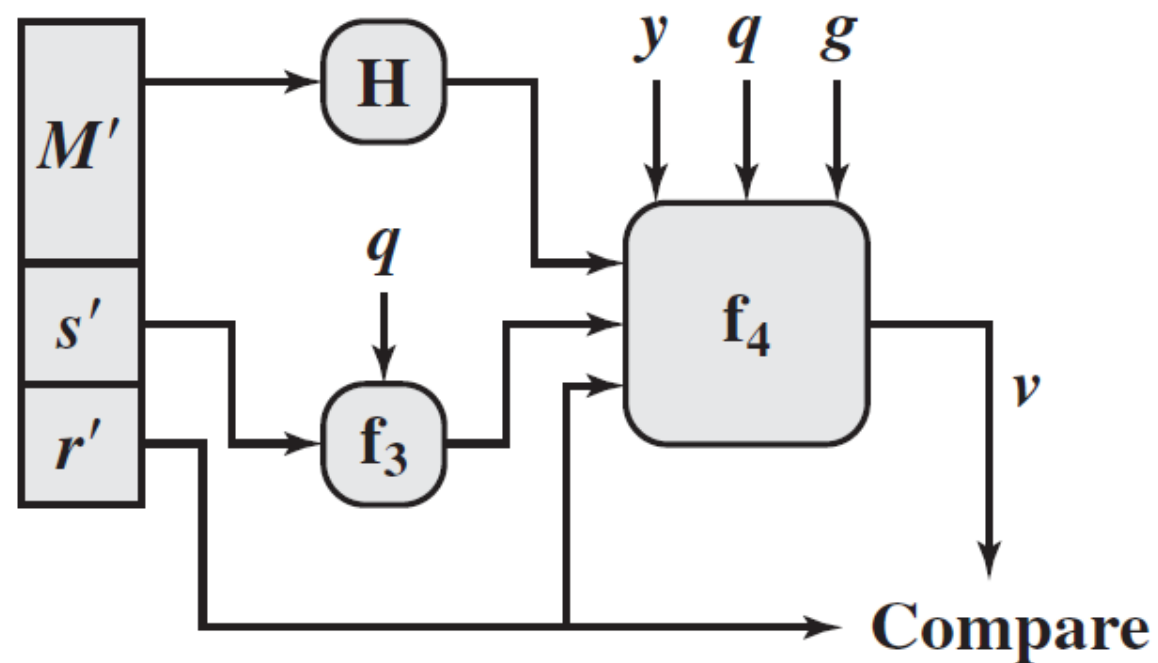
$$w = s^{-1}$$



$$s = f_1(H(M), k, x, r, q) = (k^{-1} (H(M) + xr)) \bmod q$$

$$r = f_2(k, p, q, g) = (g^k \bmod p) \bmod q$$

(a) Signing



$$w = f_3(s', q) = (s')^{-1} \bmod q$$

$$v = f_4(y, q, g, H(M'), w, r')$$

$$= ((g^{(H(M')w) \bmod q} y^{r'w \bmod q}) \bmod p) \bmod q$$

(b) Verifying

PRACTICAL DIGITAL SIGNATURE SCHEMES – THE RSA-PROBABILISTIC SIGNATURE SCHEME (RSA-PSS)

- Another practical digital signature scheme that worth its mentioned is the **RSA-Probabilistic Signature Scheme (RSA-PSS)**.
- This scheme was included in 2009's version of FIPS-186 and is the latest of the RSA schemes and the one that RSA Laboratories recommends as **the most secure** of the RSA schemes.
- For all schemes developed **prior to PSS**, developing a mathematical proof that the signature scheme is as secure as the underlying RSA encryption/decryption primitive **is NOT possible**.

PRACTICAL DIGITAL SIGNATURE SCHEMES – THE RSA-PROBABILISTIC SIGNATURE SCHEME (RSA-PSS)

- The idea of PSS was first proposed by Bellare and Rogaway.
- This approach, unlike the other RSA-based schemes, introduces a **randomization process** using **Mask Generation Function (MGF)** that enables the security of the method to be shown to be closely related to the security of the RSA algorithm itself.
- ❖ The RSA-PSS is complex and hence we will not go through the algorithm here. Interested readers may search through internet and Bellare & Rogaway's paper for a detailed architecture and construction of the scheme.

MAIN REFERENCES FOR CHAPTER 12

1. Stallings, W. “*Cryptography and Network Security: Principles and Practices*”, Fifth Edition, Pearson Prentice Hall, 2011.
2. Forouzan, B.A. “*Introduction to Cryptography and Network Security*”, Third Edition, McGraw-Hill, 2008.

~ THE END 😊 ~